

SOC L1 UYARI RAPORLAMASI

[Kaynak](#)

İÇERİK

1. Alarm Hunisi ve Triyaj Sonrası Operasyonlar (Alert Funnel)
2. Raporlama Rehberi (Reporting Guide)
3. Alarm Tırmandırma Rehberi (Escalation Guide)
4. SOC İletişimi ve Kriz Yönetimi (SOC Communication)

Alarm Hunisi ve Triyaj Sonrası Operasyonlar (Alert Funnel)

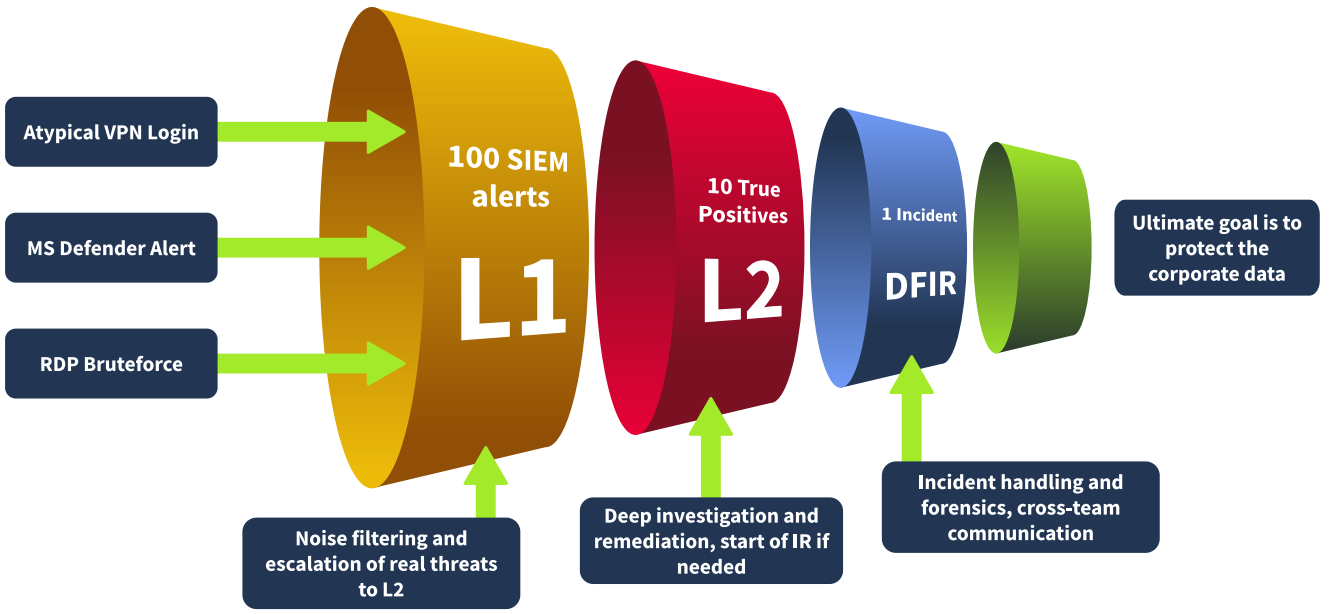
Bir **SOC** (Siber Güvenlik Operasyon Merkezi) ortamında **Alert Triage** (Alarm Triyajı - gelen güvenlik bildirimlerinin önceliklendirilmesi ve ilk incelemesi) sürecini tamamlamak, operasyonun sadece ilk aşamasıdır. Triyajın temel amacı, devasa veri yığınları arasından gerçek tehditleri ayıklamaktır. Bu süreç, geniş bir log havuzundan başlayıp kritik birkaç vakaya doğru daraldığı için kavramsal olarak bir "Huni" (Funnel) şeklinde modellenir.

Triyaj aşamasında verilen kararların, gerçek bir veri ihlalini (breach) nasıl engellediğini ve operasyonun sonraki adımlarının nasıl şekillendiğini anlamak için **Reporting** (Raporlama), **Escalation** (Tırmandırma) ve **Communication** (İletişim) olmak üzere üç temel kavramın teknik derinliğine inmemiz gerekir.

Alarm Yaşam Döngüsü: L1 ve L2 Analist Dinamikleri

Sistemde üretilen alarmlar ilk olarak **L1 (Seviye 1) Analistlerin** ekranına **SIEM** (Security Information and Event Management), **EDR** (Endpoint Detection and Response) veya kurumun kullandığı özel biletleme sistemleri (Ticket Management Platform) üzerinden düşer.

Bu noktada analitik bir filtreleme gerçekleşir. Alarmların büyük bir çoğunluğu meşru sistem davranışlarından veya hatalı kural konfigürasyonlarından kaynaklanan **False Positive** (Yanlış Pozitif - gerçekte zararlı olmayan ancak güvenlik sistemini tetikleyen olaylar) vakalar olarak sınıflandırılır ve kapatılır. Kalan alarmların bir kısmı ise L1 seviyesinde çözülebilecek basit ihlallerdir. Ancak karmaşık, yüksek riskli ve sisteme sızma belirtisi taşıyan **True Positive** (Gerçek Pozitif) alarmlar, daha derinlemesine adli bilişim analizi ve Remediation (İyileştirme/Zararı Giderme) işlemleri için **L2 (Seviye 2) Analistlere** (Incident Responders) aktarılacak zorundadır.



1. Alarm Raporlama (Alert Reporting) ve Delil Zinciri

Bir alarmı kapatmadan veya L2 ekibine aktarmadan önce, bulguların operasyonel standartlara uygun bir şekilde yazıya dökülmesi gerekir. Sadece "Bu alarm zararlıdır" gibi kısa bir yorum bırakmak, profesyonel bir SOC ortamında kabul edilemez.

Özellikle **True Positive** vakalarda, alarm raporlaması adeta bir suç mahalli tutanağı gibidir. Rapor, **IoC** (Indicator of Compromise - Uzlaşma/Sızma Göstergeleri) verilerini, zaman çizelgesini (timeline) ve ulaşılan kanıtları eksiksiz barındırmalıdır. Bu durum, analistin bulgularının geriye dönük olarak denetlenebilmesini (audit) ve yasal bir soruşturma durumunda **Chain of Custody** (Delil Zinciri) kurallarının ihlal edilmemesini sağlar.

ÖNEMLİ: Kapsamlı bir rapor, L2 analistin vakayı devraldığında sıfırdan log taraması yapmasını engeller. Siber saldırılarda zaman, saldırganın lehine işler. L1 analistin sunduğu detaylı kanıtlar, kurumun **MTTR** (Mean Time to Respond - Ortalama Müdahale Süresi) metriğini doğrudan düşürür.

Aşağıda, bir L1 analistin L2 ekibi için hazırlaması gereken standart bir rapor formatının nasıl görünmesi gerektiğine dair teknik bir şablon bulunmaktadır:

[ESCALATION REPORT – L1 to L2]

Alarm Adı: Suspicious PowerShell Execution (Bypass Execution Policy)

Tarih/Zaman: 2023-10-27 14:32:05 UTC

Etkilenen Cihaz (Host): DESKTOP-FIN-04 (192.168.1.45)

Etkilenen Kullanıcı: domain\j.doe

Bulgular ve Analiz Adımları:

- İlgili saatte j.doe kullanıcısının makinesinde "powershell.exe - ExecutionPolicy Bypass -enc <base64_payload>" komutu tespit edilmiştir.
- Parent Process (Üst Süreç) incelendiğinde, bu komutun "winword.exe" tarafından tetiklendiği EDR loglarından doğrulanmıştır. (Kullanıcının ortalama mailindeki makroyu çalıştırdığı düşünülmektedir).
- Payload decode edildiğinde, 185.15.x.x IP adresine yönelik bir C2

(Command & Control) bağlantısı kurulmaya çalışıldığı görülmüştür.

Aksiyon:

Durum True Positive olarak sınıflandırılmış, makine EDR üzerinden ağdan izole (Network Isolation) edilmiş ve derinlemesine bellek analizi (Memory Forensics) için L2 ekibine tırmandırılmıştır.

Yukarıdaki rapor formatı; olayın nerede, ne zaman, kim tarafından ve hangi teknik araçlarla (PowerShell, winword.exe) tetiklendiğini net bir şekilde ortaya koyar. L2 analisti bu raporu okuduğunda doğrudan 185.15.x.x IP adresine ve ilgili makinenin bellek dökümüne (RAM Dump) odaklanacağını bilir.

2. Tırmandırma Süreci (Alert Escalation)

Eğer incelenen **True Positive** alarm, L1 analistinin yetkilerini, araçlarını veya zaman sınırlarını (SLA) aşıyorsa, vaka L2 seviyesine taşınır (Escalate edilir). Tırmandırma sadece bir "sorumluluk atma" işlemi değildir; kurum içi mutabık kalınmış **SOP** (Standard Operating Procedures - Standart Operasyon Prosedürleri) belgelerine sıkı sıkıya bağlı kalınarak yapılan teknik bir devir teslimidir.

DİKKAT: Bir olayı tırmandırırken, sadece logları iletmek yeterli değildir. Olayın işletmeye verebileceği potansiyel zarar (Business Impact) analiz edilmeli ve L2 ekibine bu bağlamla sunulmalıdır. Örneğin, "Sıradan bir kullanıcının parolasının çalınması" ile "Domain Admin yetkisine sahip bir kullanıcının parolasının çalınması" arasında operasyonel aciliyet farkı vardır.

3. Birimler Arası İletişim (Communication) ve Bağlam Doğrulaması

Güvenlik analizleri tamamen izole bir odada, sadece loglara bakarak yapılamaz. Çoğu zaman bir olayın zararlı (Malicious) olup olmadığını belirleyen şey "Bağlam"dır (Context). Bir aktivitenin teknik olarak şüpheli görünmesi, her zaman bir saldırı olduğu anlamına gelmez. İşte bu noktada analistin diğer departmanlarla kuracağı iletişim hayati önem taşır.

- **IT Departmanı ile İletişim:** Eğer bir kullanıcı hesabında aniden **Administrator** (Yönetici) yetkileri tanımlandığını (Privilege Escalation - Yetki Yükseltme) tespit ettiyseniz, panik yapıp makineyi kapatmadan önce IT veya Sistem Yönetimi ekibiyle iletişime geçmelisiniz. Bu, planlı bir bakım çalışması veya yetkilendirilmiş bir değişiklik olabilir.
- **İK (Human Resources) Departmanı ile İletişim:** Sistemde "Yeni ve Tanımlanmamış Bir Cihazdan VPN Girişi" veya "Uzak Lokasyondan (Örn: Farklı bir ülkeden) Giriş" alarmı tetiklendiğinde, İK departmanı ile iletişime geçilerek kullanıcının yakın zamanda işe alınıp alınmadığı veya mevcut bir çalışanın o tarihlerde yurt dışı izninde olup olmadığı doğrulanmalıdır.

Mantıksal Çıkarım: Güvenlik ekiplerinin en büyük hatası, bağlamı göz ardı ederek meşru iş süreçlerini engellemektir (False Positive yorgunluğu). Doğru iletişim, operasyonel körlüğü

ortadan kaldırır ve yalnızca gerçek anormalliklere odaklanılmasını sağlar.

Raporlama Rehberi (Reporting Guide)

Bir **SOC** (Siber Güvenlik Operasyon Merkezi) ortamında L1 (Seviye 1) analistlerin görevi, gelen alarmları sadece **True Positive** (Gerçek Tehdit) veya **False Positive** (Yanlış/Zararsız Alarm) olarak işaretlemekten ibaret değildir. Salt etiketleme yapmak, kurumun siber güvenlik durumunda ölümcül bir operasyonel zafiyettir.

L1 analistlerinin detaylı bir analiz raporu yazması, teknik sürecin vazgeçilmez bir parçasıdır ve üç temel mimari/operasyonel amaca hizmet eder:

1. Tırmandırma İçin Bağlam Sağlamak (Provide Context for Escalation)

Bir alarm **True Positive** olarak değerlendirilip L2 (Seviye 2 / Incident Response) ekibine tırmandırıldığında (**Escalation**), zaman en kritik kaynaktır. L2 analistleri veya **DFIR** (Digital Forensics and Incident Response - Dijital Adli Bilişim ve Olay Müdahale) ekipleri, vakayı devraldıklarında sıfırdan log taraması yapmak zorunda kalmamalıdır. İyi yazılmış bir rapor; saldırganın sisteme nereden girdiğini, hangi kullanıcının etkilendiğini ve ilk müdahale bulgularını özetleyerek L2 ekibinin doğrudan derinlemesine analize ve **Remediation** (İyileştirme/Zararı Giderme) sürecine geçmesini sağlar. Bu durum, kurumun **MTTR** (Mean Time to Respond - Ortalama Müdahale Süresi) metriğini doğrudan iyileştirir.

2. Kayıtların Sürekli Korunması (Save Findings for the Records)

Bu madde, siber güvenlik mimarisindeki en kritik yasal ve teknik gerçeklerden biridir. **SIEM** (Security Information and Event Management) sistemleri devasa veriler işler ve veri depolama (storage) maliyetleri son derece yüksektir. Bu nedenle ham loglar (Raw Logs), sistemin kapasitesine göre genellikle 3 ila 12 ay arasında tutulur ve sonrasında üzerine yazılır veya imha edilir. Ancak bir biletleme (**Ticketing / ITSM**) sistemine düşen alarmlar ve bu alarmların içindeki raporlar süresiz olarak saklanır.

ÖNEMLİ: Aylar veya yıllar sonra kurum ağında gizli kalmış bir **APT** (Advanced Persistent Threat - Gelişmiş Sürekli Tehdit) aktörü tespit edildiğinde, geçmişe dönük yapılan araştırmalarda SIEM logları çoktan silinmiş olabilir. O gün nöbetçi olan L1 analistinin alarmın içine yazdığı detaylı rapor, kurumun elindeki tek adli dijital kanıt (Artifact) olacaktır. Rapor yazmak, sadece bugünü değil, kurumun gelecekteki adli soruşturmalarını da güvence altına almaktır.

3. Analitik Yeteneklerin Gelişimi (Improve Investigation Skills)

Teknik bir kavramı veya karmaşık bir saldırı zincirini basit ve anlaşılır bir dille ifade edemiyorsanız, olayın kök nedenini tam olarak anlamamışsınız demektir. Raporlama süreci, L1 analistini sadece ekrana bakmaktan çıkarıp olayları mantıksal bir zincire oturtmaya zorlar.

Bu "Feynman Tekniği" yaklaşımı, analistin loglar arasındaki kör noktaları fark etmesini ve kendi **Threat Hunting** (Tehdit Avcılığı) yeteneklerini keskinleştirmesini sağlar.

Rapor Formatı: "Five Ws" (5N) Yaklaşımı

Raporunuzu yazarken zihniyetiniz her zaman şu olmalıdır: *"Ben bir L2 analisti, DFIR uzmanı veya IT Sistem Yöneticisi olsaydım ve bu vakayı okusaydım, neyi görmek isterdim?"*

Mükemmel bir siber güvenlik vaka raporu, evrensel kabul görmüş **Five Ws** (Kim, Ne, Ne Zaman, Nerede, Neden) metodolojisini barındırmalıdır. Raporda hiçbir boşluk kalmamalıdır:

- **Who (Kim):** Hedef alınan veya ihlal edilen kimlik bilgisi. Sadece "admin" demek yetersizdir. Olayı tetikleyen spesifik domain kullanıcısı (**Örn: CORP\j.doe**), çalıştıran servis hesabı veya dışarıdan gelen saldırganın tanımlayıcı bilgileri verilmelidir.
- **What (Ne):** Gerçekleştirilen teknik eylemin tam anatomisi. Başarısız bir giriş denemesi mi, yetki yükseltme (**Privilege Escalation**) mi, yoksa zararlı bir dosyanın indirilip çalıştırılması mı? Çalıştırılan komut dizisi veya tetiklenen **Payload** (zararlı kod yükü) açıkça belirtilmelidir.
- **When (Ne Zaman):** Olayın zaman çizelgesi (**Timeline**). Şüpheli aktivite tam olarak ne zaman başladı ve ne zaman bitti? **DİKKAT:** Siber güvenlik raporlarında saat dilimi karışıklıklarını önlemek için istisnasız olarak her zaman **UTC (Coordinated Universal Time)** formatı kullanılmalıdır.
- **Where (Nerede):** İhlalin gerçekleştiği fiziksel veya mantıksal konum. Etkilenen uç nokta (**Endpoint**), sunucu adı (**Hostname**), iletişim kurulan iç/dış IP adresleri (Kaynak ve Hedef IP) veya spesifik bir web uygulaması URI/URL adresi.
- **Why (Neden - Karar Gerekçesi):** Raporun en can alıcı noktasıdır. Verdiğiniz kararın (**Verdict**) arkasındaki mantıksal ve teknik kanıtlar silsilesi. *"Bu alarmı kapattım çünkü..."* veya *"Bu alarmı tırmandırdım çünkü..."* cümlesinin altını dolduran kanıtlar burada yer alır.

Aşağıda, bu prensiplere göre hazırlanmış, endüstri standartlarında kusursuz bir L1 SOC Analisti rapor şablonu (örneği) bulunmaktadır:

[L1 ANALYST TRIAGE REPORT]

Verdict: True Positive (Escalated to L2)

* WHO: "CORP\finance_user" (Standart etki alanı kullanıcısı)

* WHAT: "powershell.exe -ExecutionPolicy Bypass -enc <Base64_Payload>"
komutunun çalıştırılması. Komut, şifrelenmiş bir tersine bağlantı (Reverse Shell) açmaya çalışmıştır.

* WHEN: Başlangıç: 2026-05-07 10:15:22 UTC | Bitiş: 2026-05-07 10:16:05 UTC

* WHERE: Etkilenen Host: FIN-WKSTN-04 (10.10.5.42) | C2 (Komuta Kontrol) IP: 185.x.x.x

* WHY (Analiz ve Gerekçe):

Olay incelendiğinde, ilgili kullanıcının Outlook üzerinden gelen şüpheli bir e-posta ekini (invoice_2026.doc) açtığı EDR loglarından tespit edilmiştir.

Word belgesinin bir alt süreç (child process) olarak PowerShell'i gizli modda (hidden window) başlattığı ve dışarıdaki bir C2 sunucusuyla iletişim kurmaya çalıştığı doğrulanmıştır. Tehdit İstihbaratı platformlarında dış IP adresi "Malicious" (Zararlı) olarak listelenmektedir. Kullanıcının hesabı askıya alınmış, makine ağdan izole edilmiş ve derinlemesine bellek analizi (Memory Forensics) için vaka L2 ekibine tırmandırılmıştır.

Yukarıdaki çıktı bloğu, aylar sonra bile okunduğunda SIEM loglarına ihtiyaç duymaksızın olayın tüm bağlamını, kanıtlarını ve alınan aksiyonları eksiksiz bir biçimde aktaran kusursuz bir adli belge niteliği taşır.

Alarm Tırmandırma Rehberi (Escalation Guide)

Triyaj (Triage) sürecini tamamlayıp, bulgularınızı detaylı bir teknik raporda birleştirdikten sonra, bir L1 (Seviye 1) analisti olarak en kritik operasyonel kararlardan biriyle karşı karşıya kalırsınız: **Escalation** (Tırmandırma - Bir vakayı, daha yetkili veya tecrübeli bir üst seviyeye, genellikle L2 ekibine devretme işlemi).

Tırmandırma rastgele yapılan bir eylem değildir; kurumun olay müdahale (Incident Response) kapasitesini doğrudan etkileyen stratejik bir adımdır. Karar mekanizmaları kurumdan kuruma değişiklik gösterse de, bir siber güvenlik operasyon merkezinde (SOC) evrensel kabul görmüş tırmandırma senaryolarının mantıksal arka planını tam olarak kavramak zorunludur.

Tırmandırma Kararını Tetikleyen Kritik Senaryolar

Her alarm L2'ye gönderilmez. L1 analistinin temel görevi gürültüyü filtrelemektir. Ancak aşağıdaki dört senaryodan biriyle karşılaşıldığında, vakanın derhal tırmandırılması operasyonel bir zorunluluktur:

İlk olarak, olayın çapı standart bir kural ihlalini aşıyorsa tırmandırma şarttır. İncelediğiniz alarm sıradan bir zararlı yazılım (Malware) değil de, ağda yanal hareket (Lateral Movement) yapan ve kritik sistemleri hedef alan organize bir siber saldırı göstergesiye, bu durum derinlemesine bir **DFIR** (Digital Forensics and Incident Response - Dijital Adli Bilişim ve Olay Müdahale) süreci gerektirir. L1'in araç seti ve zamanı bu derinlikteki bir analiz için yetersiz kalacaktır.

İkinci olarak, olay **Remediation** (İyileştirme/Zararı Giderme) aksiyonları gerektiriyorsa süreç L2'ye aktarılır. Eğer inceleme sonucunda bir sunucunun ağdan izole edilmesi (Host Isolation), bulaşan kalıcı bir zararlının sistemden kazınması veya kritik yöneticilerin parolalarının zorla sıfırlanması gerekiyorsa, bu yetkiler ve sorumluluk genellikle L2 analistlerinde veya sistem yöneticilerindedir. Yanlış bir izolasyon komutu kurumun tüm üretim ağını durdurabileceği için bu aksiyonlar üst seviyenin onayı ve icrasıyla gerçekleştirilir.

Üçüncü senaryo, iletişimin yasal veya kurumsal sınırları aştığı durumlardır. Eğer gerçekleşen ihlal müşterilerin verilerini, iş ortaklarını kapsıyor veya kolluk kuvvetleriyle yasal bir süreç

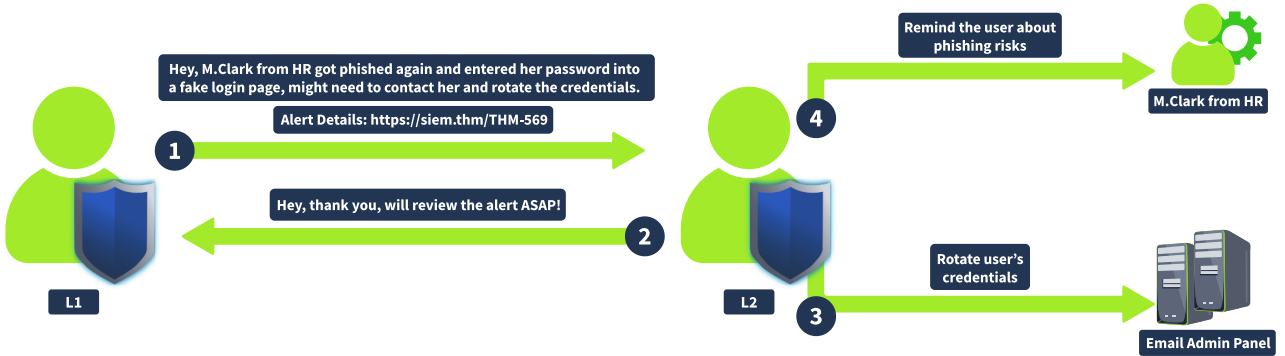
yürütülmesini zorunlu kılıyorsa, bu iletişim L1 seviyesinde yönetilemez.

Son olarak ve en önemlisi; teknik sınırlarınıza ulaştığınız durumlardır. Ekrana düşen aktivitenin meşru bir sistem davranışı mı yoksa sofistike bir **Obfuscation** (Gizleme/Karmaşılaştırma) tekniği mi olduğunu tam olarak anlayamadıysanız, daha kıdemli analistlerden destek istemek zorundasınız.

DİKKAT: Siber güvenlikte yapılan en büyük ölümcül hata, teknik olarak tam anlaşılamayan bir alarmı "muhtemelen bir şey yoktur" diyerek körü körüne **False Positive** (Yanlış Pozitif - Zararsız Alarm) olarak kapatmaktır. Anlamadığınız bir alarmı kapatmak, kurumun siber güvenlik duruşunda geri dönüşü olmayan bir zafiyet (Blind Spot) yaratır.

L2 Devir Teslimi ve Operasyonel Akış (Escalation Steps)

Tırmandırma sürecinin mekaniği genellikle platform üzerinden yürütülür. Çoğu modern SOC ortamında bu süreç; SIEM (Security Information and Event Management) veya biletleme (Ticketing) sistemi üzerinden alarmın nöbetçi L2 analistine atanması (Reassign) ve ardından kurumsal iletişim kanallarından (Slack, Teams vb.) hızlıca bilgi verilmesi şeklinde işler. Daha katı kurallara sahip ekiplerde ise onlarca spesifik alanın doldurulduğu resmi bir tırmandırma talebi (Escalation Request) oluşturulması gerekebilir.



Süreç nasıl işlese işlesin, L2 analisti vakayı devraldığında sıfırdan log avına çıkmaz; sizin yazdığınız raporu okur. Eğer L1 raporu kusursuz hazırlanmışsa, L2 analisti bulguları hızla doğrular (**True Positive** teyidi), eksik kalan teknik detayları (örneğin bellek analizi) tamamlar ve tehdit ciddi boyutlardaysa resmi **Incident Response** (Olay Müdahale) sürecini başlatır.

SOC Dashboard Üzerinde Standart Tırmandırma İş Akışı

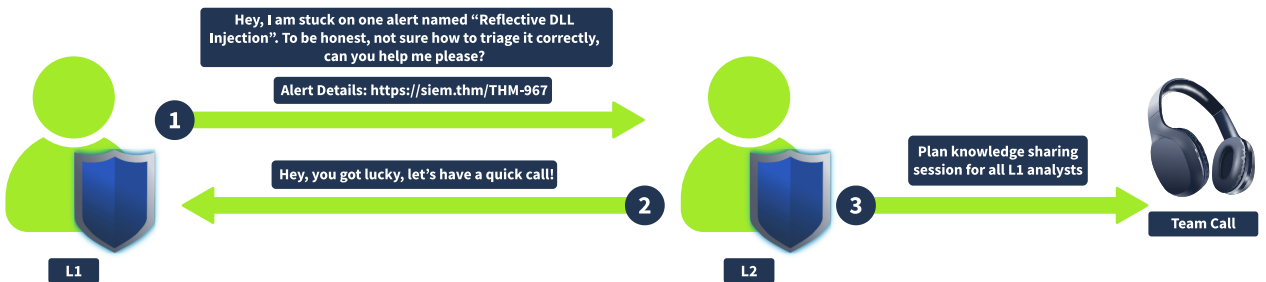
Bir alarmın platform üzerindeki yaşam döngüsünü L1 perspektifinden adım adım teknik bir log akışı mantığıyla inceleyelim. Aşağıdaki yapı, bir SIEM/SOAR platformunda biletin durum değişikliklerinin (State Transition) arka planda nasıl kaydedildiğini gösterir:

```
{
  "ticket_id": "INC-8892",
  "workflow_steps": [
    {
      "step": 1,
      "action": "Status Update",
      "value": "In Progress",
```

```
"analyst_comment": "Analiz için sahiplik alındı. Analist çıkışmasını  
(Collision) önlemek için bilet kilitlendi."  
},  
{  
  "step": 2,  
  "action": "Analysis & Reporting",  
  "value": "Completed",  
  "analyst_comment": "Hedef makinede PowerShell üzerinden Base64  
şifrelenmiş Reverse Shell tespiti doğrulandı. Detaylı bulgular rapora  
eklendi."  
},  
{  
  "step": 3,  
  "action": "Verdict Assignment",  
  "value": "True Positive",  
  "analyst_comment": "Olay gerçek bir tehdit (True Positive) olarak  
sınıflandırıldı."  
},  
{  
  "step": 4,  
  "action": "Reassignment / Escalation",  
  "value": "Assigned to: L2_OnShift_Queue",  
  "analyst_comment": "Host Isolation ve Memory Forensics talebiyle L2  
ekibine tırmandırıldı."  
}  
]  
}
```

Yukarıdaki JSON mimarisindeki iş akışı, L1 analistinin tırmandırma sürecindeki değişmez adımlarını temsil eder. *In Progress* durumuna alınmayan bir bilette başka analistler de vakit kaybedebilir. Analiz yapılmadan ve *True Positive* (Gerçek Tehdit) kararı verilmeden L2'ye gönderilen bir bilet, yetersiz ön inceleme nedeniyle L2 ekibinde operasyonel darboğaz (Bottleneck) yaratır.

ÖNEMLİ: Özellikle kariyerinizin ilk aylarında, prosedürleri ve kurumun ağ yapısını tam öğrenene kadar kıdemli analistlerden destek istemek ve tartışmak (Requesting L2 Support) son derece olağandır. L2 ekibi, sizin raporunuzdan yola çıkarak tehdidi avlayacaktır; bu nedenle raporunuzdaki her kanıtın (IoC - Indicator of Compromise) ve kararın, mantıksal bir teknik temele dayandığından emin olun.



SOC İletişimi ve Kriz Yönetimi (SOC Communication)

Siber Güvenlik Operasyon Merkezi (SOC) ortamında tırmandırma (**Escalation**) ve raporlama (**Reporting**) süreçleri kağıt üzerinde son derece mantıklı ve doğrusal görünür. Ancak operasyonel sahada (özellikle aktif bir saldırı altındayken) işler nadiren planlandığı gibi gider. Beklenmedik senaryolara hazırlıklı olmak ve kriz anında doğru iletişim kanallarını kullanmak, teknik analiz yeteneğiniz kadar kritiktir.

Olgun bir SOC ekibinin mutlaka bir **Crisis Communication** (Kriz İletişimi) prosedürü veya başvuru rehberi (**Playbook / SOP**) bulunur. Eğer böyle bir rehber yoksa bile, bir analist olarak aşağıdaki kritik senaryoları ve arka plandaki teknik mantıklarını içselleştirmiş olmanız beklenir.

Kritik Vaka 1: İletişim Kopukluğu ve Erişilemeyen L2 Analist

Senaryo: Son derece acil ve kritik (Critical) bir alarmı tırmandırmanız gerekiyor, ancak nöbetçi L2 analisti ulaşamaz durumda ve 30 dakikadır yanıt vermiyor.

Mantıksal Derinlik ve Aksiyon: Siber güvenlikte zaman, saldırganın en büyük silahıdır. 30 dakikalık bir gecikme, saldırganın ilk erişimi (Initial Access) sağladıktan sonra ağ içinde **Lateral Movement** (Yanal Hareket) yapıp Domain Controller gibi kritik sunuculara sıçraması için fazlasıyla yeterli bir süredir. Bu durum doğrudan bir **SLA (Service Level Agreement - Servis Seviyesi Anlaşması)** ihlalidir.

Böyle bir durumda pasif kalıp beklemek en büyük operasyonel hatadır. Kurumun Acil Durum İletişim Matrisini (**Emergency Contacts**) dev devreye sokmalısınız. Hiyerarşik tırmandırma kuralı gereği; önce L2 analisti doğrudan cep telefonu ile aranmalı, ulaşamıyorsa bir üst seviye olan **L3 Analist / Olay Müdahale Uzmanı (Incident Responder)** aranmalı, o da yoksa doğrudan **SOC Manager** (SOC Yöneticisi) durumdan haberdar edilmelidir. Sistemin yanmasını izlemek yerine hiyerarşiyi by-pass etmek kriz anlarında meşrudur.

Kritik Vaka 2: Ele Geçirilen İletişim Kanalları (Out-of-Band Communication)

Senaryo: Kullanıcının Slack veya Microsoft Teams hesabının ele geçirildiğine (**Compromised**) dair bir alarm aldınız. Olayı doğrulamak (Validate) için kullanıcıyla iletişime geçmeniz gerekiyor.

Mantıksal Derinlik ve Aksiyon: ÖNEMLİ: Siber savaşta kural sıfırdır: İhlal edildiğinden şüphelendiğiniz hiçbir platform üzerinden doğrulama yapılamaz! Eğer bir hesaba sızıldıysa (**Credential Theft** veya **Session Hijacking**), o platform üzerinden "Hesabınıza farklı bir yerden giriş yapıldı, siz miydiniz?" diye sormak, doğrudan saldırganla mesajlaşmak anlamına gelir. Saldırgan rahatlıkla "Evet bendim, sorun yok" diyerek sizi manipüle edebilir.

Bu senaryoda derhal **Out-of-band communication** (Bant dışı iletişim) yöntemleri kullanılmalıdır. Ele geçirilen ağın veya uygulamanın tamamen dışında bir kanal (doğrudan

kullanıcının şahsi cep telefonunu aramak veya ofisteyse yanına fiziksel olarak gitmek)
kullanılarak kimlik ve aktivite teyidi alınmalıdır.

Kritik Vaka 3: Alarm Yağmuru (Alert Fatigue) ve Önceliklendirme

Senaryo: Çok kısa bir süre içinde, bir kısmı "Critical" (Kritik) olan yüzlerce alarm SIEM ekranınıza düştü.

Mantıksal Derinlik ve Aksiyon: Buna endüstride **Alert Fatigue** (Alarm Yorgunluğu) veya kasıtlı bir **Diversion/Smokescreen** (Şaşırtma/Sis Perdesi) saldırısı denir. Gelişmiş Tehdit Aktörleri (**APT - Advanced Persistent Threat**), asıl hedeflerine (örneğin veri sızdırma - **Data Exfiltration**) sessizce ulaşırken, SOC ekibinin dikkatini dağıtmak için ağır başka bir köşesinde bilerek gürültü (**Noise**) yaratacak kaba kuvvet (Brute Force) veya DDoS saldırıları başlatabilirler.

Burada yapılması gereken, paniklemek yerine operasyonel iş akışına (**Triage Workflow**) sadık kalmaktır. Tüm alarmları önceliklendirin ve sadece **Critical** olanlara odaklanın. Ancak asıl kritik adım; bu anomaliyi derhal nöbetçi L2 analistine raporlayarak ekibin durumsal farkındalığını (**Situational Awareness**) artırmaktır.

Kritik Vaka 4: Geç Fark Edilen Hatalı Sınıflandırma (Misclassification)

Senaryo: Birkaç gün önce bir alarmı incelediniz, **False Positive** (Yanlış Pozitif/Zararsız) olarak kapattınız. Ancak günler sonra, o alarmı yanlış sınıflandırdığınızı ve aslında sistemde zararlı bir aktiviteyi (Malicious Action) gözden kaçırdığınızı fark ettiniz.

Mantıksal Derinlik ve Aksiyon: L1 analistleri hata yapabilir, ancak bu hatayı gizlemek siber güvenlikteki en büyük profesyonel ihlaldir. Tehdit aktörleri sisteme ilk sızdıklarında her zaman anında yıkıcı bir zarar (örneğin Ransomware şifrelemesi) vermezler. Sistemde kalıcılık (**Persistence**) sağladıktan sonra haftalarca, bazen aylarca sessiz kalabilirler. Bu bekleme süresine **Dwell Time** (Ağda Barınma Süresi) denir.

Eğer bir hatayı fark ederseniz, saldırgan hala "Dwell Time" evresinde olabilir ve kurumu kurtarmak için hala vaktiniz vardır. Derhal L2 analistine ulaşmalı ve durumu açıklamalısınız.

Aşağıda, böyle bir durumu L2'ye bildirirken kullanmanız gereken profesyonel ve teknik bir **Retroactive Escalation** (Geriye Dönük Tırmandırma) iletişim bloğu örneği verilmiştir:

[RETROACTIVE ESCALATION – CRITICAL UPDATE]

Ticket ID: INC-1045 (Önceden Kapatılan Bilet)

Tarih/Zaman: 2026-05-04 09:15 UTC

Konu: Hatalı Triage Bildirimi ve Olası True Positive Şüphesi

Sayın L2 Ekibi,

4 Mayıs tarihinde "Suspicious WMI Activity" kuralıyla düşen INC-1045 numaralı bileti, yetkili bir IT admininin planlı bir taraması olduğunu

düşünerek "False Positive" olarak kapatmıştım.

Ancak bugün yaptığım geriye dönük incelemede, WMI komutunu çalıştıran sürecin (Parent Process) "svchost.exe" değil, geçici bir dizinden (\AppData\Local\Temp) çalışan şüpheli bir binary olduğunu fark ettim. Saldırganın WMI üzerinden kalıcılık (Persistence) sağlamış olmasından şüpheleniyorum. İlgili makinenin (HOST-SRV-02) ağda hala aktif olduğunu görüyorum.

Acil olarak bu host üzerinde EDR üzerinden derinlemesine bir Threat Hunting (Tehdit Avı) başlatılmasını rica ederim. Hatadan dolayı özür diler, inceleme için log ID'lerini ekte sunarım.

Bu tür şeffaf ve teknik detaya inen bir iletişim, olası bir felaketi önlediği gibi sizin profesyonelliğinizi de kanıtlar.

Kritik Vaka 5: İşlenemeyen ve Okunamayan SIEM Logları (Unparsed Logs)

Senaryo: Alarm triyajı yapmaya çalışıyorsunuz ancak **SIEM** (Security Information and Event Management) üzerindeki loglar doğru ayrıştırılmamış (Parsed) veya içinde arama yapılamıyor (Unsearchable).

Mantıksal Derinlik ve Aksiyon: Log ayrıştırma (Parsing), ham log verisinin (örneğin karmaşık bir Syslog formatının) SIEM tarafından anlaşılır alanlara (IP, Kullanıcı, Port) bölünmesi işlemidir. Eğer parsing bozuksa, korelasyon kuralları çalışmaz ve kör noktalar (**Blind Spots**) oluşur.

DİKKAT: "Log okunamıyor, analiz yapılamaz" diyerek alarmı atlamak veya kapatmak (Skip) kesinlikle yasaktır!

Elinizdeki bozuk formattaki ham log metninden (**Raw Payload**), manuel olarak gözle okuyabildiğiniz kadar veriyi (IP adresleri, URL'ler, User-Agent bilgileri) çıkartıp analiz etmeye çalışın. Ardından süreci L2'ye devredin ve bu parsing hatasını derhal bir **SOC Engineer**'a (SOC Mühendisi) raporlayın. Veri hattındaki (Data Pipeline) bu kırılma, güvenlik duruşunu temelden sarsan altyapısal bir zafiyettir.

L2 Tarafından Yürütülen İletişim (Communication By L2)

Siz (L1) bir alarmı doğru bir raporla tırmandırdıktan sonra, iletişim bitmez; sadece seviye atlar. **L2 Analistleri**, vakanın boyutuna göre Hukuk departmanı (veri ihlali bildirimi için), İnsan Kaynaklarıyla (içeriden tehdit - **Insider Threat** vakaları için) veya doğrudan müşterilerle kriz iletişimini yönetmeye başlar. Sizin başlangıçta yazdığınız o "eksiksiz ve teknik" triyaj raporu, kurumun en tepe yönetiminin alacağı stratejik kararların temel dayanağı

olacaktır.

